Roteiro de Apresentação — Tema 1: Segurança em APIs REST e Microsserviços

Oct 9, 2026 · @eduty

A apresentação tem 13 slides em 20 minutos, divididos em quatro blocos de um integrante cada, para Nov 5, 2026.

Visão geral

Os quatro blocos seguem a estrutura exigida pelo professor e somam 20 minutos, dentro do limite de 18 a 22.

Bloco	Parte exigida	Slides	Tempo	Quem	Início
1	Introdução e conceituação	1 a 4	4 min	A	0:00
2	Funcionamento e arquitetura	5 a 8	6 min	B	4:00
3	Aplicação prática e código	9 a 11	6 min	C	10:00
4	Conclusão	12 e 13	4 min	D	16:00

As letras A a D são os quatro integrantes; o grupo decide quem fica com cada bloco. O conteúdo de apoio de cada slide está no documento de contexto: Segurança em APIs REST e Microsserviços — Documento de Contexto… . A coluna "Apoio" das tabelas abaixo indica a seção dele.

Se o tempo apertar, o corte previsto é o slide 8 (rate limiting e CORS) reduzido a 45 segundos, e o slide 11 mostrado só como tabela, sem demonstração.

Bloco 1 — Introdução e conceituação (4 min, integrante A)

O bloco responde às três perguntas da parte 1: o que é, que problema resolve e onde entra no ciclo de vida.

#	Slide	Tempo	O que mostrar	O que falar	Apoio
1	Segurança em APIs REST e Microsserviços	0:30	Tema, integrantes, disciplina e data	Apresentar o grupo e dizer em uma frase o que o público vai levar: como proteger uma API em cinco frentes.	1

#	Slide	Tempo	O que mostrar	O que falar	Apoio
2	O que é uma API REST e o que são microsserviços	1:15	Uma figura: monólito de um lado, vários serviços conversando por HTTP do outro	API REST é o contrato HTTP pelo qual sistemas trocam dados. Microsserviços dividem o sistema em serviços pequenos. No monólito a chamada interna não passa pela rede; nos microsserviços, toda chamada é uma requisição.	4
3	Por que a API virou o alvo	1:15	Um caso real em três linhas e os números de 2026	A API entrega o dado puro, sem a tela filtrando. Contar um caso (Optus ou Dell) e fechar com a frase: as falhas mais caras são as mais simples. Citar a fonte dos números.	5
4	Onde isso entra no ciclo de vida	1:00	Linha do requisito à desativação, com um controle por fase	Segurança de API não é etapa final: começa no requisito e vai até desligar versões antigas. Quanto mais cedo, mais barato corrigir.	7

Passagem para o bloco 2: "Agora que sabemos o que proteger e por quê, vamos ver como as ameaças se organizam e como cada defesa funciona."

Bloco 2 — Funcionamento e arquitetura (6 min, integrante B)

O bloco cobre a parte 2: modelo de ameaças, diagramas e protocolos. É o que mais tende a estourar o tempo, então cada slide tem 1 minuto e meio.

#	Slide	Tempo	O que mostrar	O que falar	Apoio
5	OWASP API Security Top 10 (2023)	1:30	A lista dos dez riscos, com os itens do nosso escopo destacados	A OWASP mantém uma lista só para APIs. Três dos cinco primeiros itens são falhas de autorização. Autenticar bem não basta: falta conferir se o usuário pode fazer aquilo com aquele objeto.	6.1

#	Slide	Tempo	O que mostrar	O que falar	Apoio
6	Defesa em camadas	1:30	Diagrama das camadas de defesa ou da arquitetura de referência	A requisição atravessa várias camadas e pode ser recusada em qualquer uma. O gateway concentra o que é comum; cada serviço confere de novo, porque a rede interna não é confiável (Zero Trust).	6.4 e 12.2
7	Autenticação por token	1:30	As três partes do JWT e o fluxo da requisição	A API não guarda sessão, então cada requisição leva um token. O JWT é assinado, não cifrado: qualquer um lê, ninguém altera. A API confere assinatura, validade, emissor e audiência. Não detalhar OAuth: é o Tema 2.	8.3 e 8.4
8	Rate limiting e CORS	1:30	O balde de fichas em uma figura; o diagrama do preflight	Rate limiting limita quantas requisições um cliente faz e responde 429. CORS diz ao navegador quais sites podem ler a resposta. CORS protege o usuário no navegador, não a API contra acesso direto.	9.2 e 10.3

Passagem para o bloco 3: "Vimos o desenho. Agora vamos ver como isso fica no código de uma API de pedidos."

Bloco 3 — Aplicação prática e código (6 min, integrante C)

O bloco cobre a parte 3 com a API de pedidos do documento de contexto: o código corrigido, o motivo da correção e o resultado.

#	Slide	Tempo	O que mostrar	O que falar	Apoio
9	Autorização por objeto	2:00	A mesma rota em duas versões, lado a lado, com a linha da correção destacada	Na primeira versão a busca usa só o ID recebido. Na corrigida, o dono do pedido entra na busca e a resposta passa por um filtro de campos. Uma linha de código separa as duas.	13.1

#	Slide	Tempo	O que mostrar	O que falar	Apoio
10	Validação de payload	2:00	O schema da requisição, com a regra que rejeita campos desconhecidos	A API declara o formato que aceita e recusa o resto. Tipos, tamanhos e campos permitidos ficam no schema, não espalhados pelo código. A validação do front-end é experiência de uso; a do servidor é segurança.	13.6
11	A API em funcionamento	2:00	A tabela de resultados, ou a demonstração ao vivo de duas requisições	Mostrar que cada controle responde com seu código: 401, 403 ou 404, 400, 429. Fechar dizendo o que o exemplo simplifica: dados em memória, sem gateway, limite por IP.	13.8 e 13.9

Regras para o código em slide: no máximo 10 a 12 linhas, fonte grande e fundo com bom contraste. Quem apresenta lê a linha destacada, não o trecho inteiro.

Se optarem pela demonstração ao vivo, ela substitui a tabela e usa só as duas rotas do slide 9. Deixar o terminal aberto e com a fonte ampliada antes de começar, e ter um vídeo curto gravado como reserva.

Passagem para o bloco 4: "Cada controle cobriu uma parte. Vamos fechar com o que cada um não resolve e o que recomendamos."

Bloco 4 — Conclusão (4 min, integrante D)

O bloco cobre a parte 4: principais conclusões e recomendações para desenvolvedores.

#	Slide	Tempo	O que mostrar	O que falar	Apoio
12	Vantagens x desvantagens	2:00	Tabela resumida: cada controle, o benefício, o custo e o que ele não resolve	Microsserviços isolam melhor, mas ampliam a superfície e exigem mais maturidade. Nenhum controle basta sozinho: a coluna "não resolve" mostra por que a defesa é em camadas.	14.3

#	Slide	Tempo	O que mostrar	O que falar	Apoio
13	Recomendações e referências	2:00	Checklist curto de cinco ou seis itens e as fontes principais	Ler o checklist como hábitos de toda rota: autenticar, conferir o dono, validar a entrada, filtrar a saída, limitar a taxa, manter o inventário. Encerrar com a frase central e abrir para perguntas.	15.2 e 18

Frase de encerramento sugerida: "As falhas de API mais caras são simples, quase sempre de autorização, e a defesa é um conjunto de hábitos aplicados em cada rota."

Ensaio e checklist do dia

A sugestão é fazer dois ensaios com cronômetro: o primeiro mede quanto cada bloco leva de fato, e o segundo confirma os cortes.

Antes do dia

- [ ] Definir quem é A, B, C e D.
- [ ] Montar os 13 slides a partir do documento de contexto.
- [ ] Ensaiar uma vez com cada um falando só o seu bloco, cronometrado.
- [ ] Ensaiar uma vez completo, com as frases de passagem.
- [ ] Decidir entre demonstração ao vivo e tabela de resultados no slide 11.
- [ ] Se houver demonstração, gravar o vídeo de reserva.
- [ ] Enviar os slides pelo SUAP antes da apresentação.
- [ ] Combinar quem responde perguntas de cada assunto.

No dia

- [ ] Slides abertos em um computador testado no projetor, com cópia em PDF.
- [ ] Cronômetro visível para quem está apresentando.
- [ ] Sinal combinado para avisar quando faltar 30 segundos do bloco.
- [ ] Se houver demonstração: API já em execução e terminal com fonte ampliada.

Marcas de tempo

Momento	Relógio	Se estiver atrasado
Fim do bloco 1	4:00	Encurtar o slide 5 para a frase sobre autorização

Momento	Relógio	Se estiver atrasado
Fim do bloco 2	10:00	Reduzir o slide 8 a 45 segundos
Fim do bloco 3	16:00	Mostrar o slide 11 só como tabela
Encerramento	20:00	Ler três itens do checklist em vez de seis

Perguntas prováveis

As respostas abaixo cabem em uma ou duas frases; o detalhe de cada uma está no documento de contexto.

Pergunta	Resposta curta	Apoio
Qual a diferença entre autenticação e autorização?	Autenticação identifica quem é; autorização decide o que pode. Uma responde 401, a outra 403.	8.1
JWT é seguro? Dá para ler o conteúdo?	É assinado, não cifrado. O conteúdo é legível; a assinatura impede alteração.	8.3
Como revogar um JWT?	Vida curta, rotação de refresh token e lista de identificadores revogados.	8.5
CORS protege a API de quem não usa navegador?	Não. CORS é aplicado pelo navegador para proteger o usuário.	10.2
Rate limit por IP é suficiente?	Não. Vários usuários dividem um IP. Combinar com limite por usuário e por rota.	9.3
O gateway já valida o token; por que validar no serviço?	Defesa em profundidade e Zero Trust: o serviço não confia na rede interna.	12.4
Microsserviços são mais seguros que monólito?	Depende. Isolam melhor, mas ampliam a superfície e exigem mais maturidade.	14.1
Qual a diferença entre validar e sanitizar?	Validar rejeita o que foge da regra; sanitizar transforma o dado.	11.1
Por que 404 e não 403 ao negar um objeto de outro usuário?	Para não confirmar que o objeto existe.	13.1
Isso não é o mesmo que o Tema 2 ou o Tema 8?	Eles aprofundam uma peça cada. O nosso mostra como as peças se juntam na API.	1